

Entra ID SSO — Quick Start

Expense Management Platform · the minimum to switch on Microsoft SSO

1 · In the Azure Portal (one-time)

1. Entra ID → App registrations → New registration. Copy the Application (client) ID and Directory (tenant) ID.
2. Add a Web redirect URI: `http://localhost:3000/api/auth/callback/microsoft-entra-id` (http is OK for localhost; port 3000 = portal, not 8000)
3. Certificates & secrets → New client secret. Copy the Value now (shown once).
4. Token configuration → add the email optional claim.

2 · Backend (FastAPI) — environment variables

The only switch that turns SSO on is `APP_AUTH_PROVIDER=entra`. Issuer/JWKS are derived from the tenant automatically.

```
APP_AUTH_PROVIDER=entra
APP_ENTRA_TENANT_ID=<Directory (tenant) ID>
APP_ENTRA_AUDIENCE=<Application (client) ID>
APP_OIDC_AUTO_PROVISION=false           # true = auto-create unknown users
APP_CORS_ALLOW_ORIGINS=http://localhost:3000
```

3 · Frontend (Next.js / Auth.js) — environment variables

The “Sign in with Microsoft” button appears automatically once `_ID` and `_ISSUER` are set.

```
AUTH_SECRET=<openssl rand -base64 32>
AUTH_MICROSOFT_ENTRA_ID_ID=<Application (client) ID>
AUTH_MICROSOFT_ENTRA_ID_SECRET=<client secret value>
AUTH_MICROSOFT_ENTRA_ID_ISSUER=https://login.microsoftonline.com/<tenant-id>/v2.0
NEXT_PUBLIC_API_BASE_URL=http://localhost:8000
# optional – silent token refresh:
AUTH_OIDC_TOKEN_URL=https://login.microsoftonline.com/<tenant-id>/oauth2/v2.0/token
AUTH_OIDC_CLIENT_ID=<Application (client) ID>
AUTH_OIDC_CLIENT_SECRET=<client secret value>
```

4 · Verify

Restart both apps → open `http://localhost:3000` → “Sign in with Microsoft” → sign in → land on the role dashboard. Backend check:

```
curl -H "Authorization: Bearer <token>" http://localhost:8000/auth/me
```

Top gotchas

- Redirect URI must match EXACTLY (scheme + host + PORT + `/api/auth/callback/microsoft-entra-id`).
- Use localhost, not 127.0.0.1 — Entra treats them as different origins; browse to whichever you registered.
- Missing/changed `AUTH_SECRET` → login loops back to `/login` (cookie can’t decrypt).
- 401 from API → `APP_ENTRA_AUDIENCE` must equal the client ID; check tenant ID.
- “Contact your administrator” → user has no DB account and auto-provision is off.
- Authorization (role + agency) lives in YOUR database — Entra only authenticates.